ANEXO TÉCNICO

Dirigir agentes de IA en un proyecto Android real

Prompts, delegación y verificación en FinControl

Asignatura: Programación Android · IEI-093 · Unidad 2, Semana 10

Actividad: 2.5 — Manejo de elementos de seguridad

Proyecto: FinControl — control de gastos, ingresos y suscripciones

Agente: Agente de código autónomo en terminal, con subagentes

Fecha: 30 de octubre de 2026

> *Nota de método: los prompts son la reconstrucción técnica de lo que pedí, no una transcripción literal. Los commits citados están en el historial Git del clon local del equipo; el 30/10/2026 el repositorio público de GitHub se consolidó con un reset para blindar la clave de Google Maps expuesta en la v1 (nota de la sección 9 del informe).*

Resumen

Qué	Resultado
Qué construyó el agente	Código, documentación y análisis de seguridad, bajo mis restricciones
Qué decidí yo	Alcance, decisiones de producto y criterios de aceptación de cada iteración
Vulnerabilidades cerradas	6 de 6, con MobSF antes y después (re-análisis sin hallazgos de severidad alta o media)
Verificación final	Compilación limpia, 9 pruebas automáticas y 5 pruebas manuales en el teléfono

FinControl se construyó en dos jornadas de trabajo dirigido: yo definí qué construir y cómo se aceptaría; el agente escribió el código y lo compiló para que yo lo probara en el teléfono.

Cómo dirigí al agente (4 reglas)

- Rol y stack desde el primer comando: nada de propuestas genéricas.
- Requisitos numerados (S1–S24) en el repositorio: se pide «implementa S22», no se re-explica.
- Subagentes en paralelo para módulos independientes; en serie lo que toca el esquema de datos o la seguridad.
- Yo probaba en el teléfono y solo entonces se cerraba la iteración. Dos veces dije que no, y las dos decisiones subieron la calidad.

Los nueve prompts

De cada prompt va lo esencial: qué pedí y qué quedó verificado.

PROMPT

> Actúa como líder técnico del proyecto. Stack: Java 11, minSdk 30, targetSdk 36, SQLiteOpenHelper y Material 3. Primero el esqueleto Gradle, el manifiesto y el esquema de base de datos; no avances a los módulos hasta que el APK compile limpio.

Prompt 1 · Arranque Esqueleto, esquema v1 y compilación verificada (dd30f2a).

PROMPT

> Autenticación con PBKDF2-SHA256, sal por usuario y 150.000 iteraciones, comparación con MessageDigest.isEqual. Todas las consultas parametrizadas. Sesión en EncryptedSharedPreferences con MasterKey AES256_GCM, nada de texto plano.

Prompt 2 · Seguridad desde el modelo de datos UserDao con hash salado y consultas parametrizadas (8ff0560).

PROMPT

> Lo instalé y el contenido se mete bajo la status bar: corregiste márgenes, no el diseño. Necesito edge-to-edge resuelto con insets de systemBars y displayCutout en un helper común a las 8 pantallas, y después un rediseño Material 3 con roles de tema.

Prompt 3 · Interfaz con evidencia InsetsHelper en las ocho actividades y rediseño completo (30f7aff).

PROMPT

> Corre MobSF sobre el APK debug y pásame cada hallazgo con severidad y PoC. Después corriges uno por uno y vuelves a analizar. Quiero el antes y el después en el historial, no solo el resultado final.

Prompt 4 · Auditoría con herramienta Seis hallazgos documentados, corregidos y re-analizados.

PROMPT

> Integra Google Maps: SupportMapFragment con OnMapReadyCallback y un marcador por cada gasto con ubicación. La clave va en local.properties y se inyecta al compilar, nunca en el código. Si falta la clave, la pantalla se degrada, no se cae.

Prompt 5 · Clave fuera del código Mapa verificado en emulador; clave restringida por paquete y SHA-1 (d666190).

PROMPT

> Categorías sembradas y ordenadas por uso, drag & drop, plantillas con sugerencia, navegación por meses y swipe-to-delete con deshacer. Base de datos v4 con migraciones aditivas: no quiero perder datos de instalaciones anteriores.

Prompt 6 · Funciones sin romper datos Doce funciones y esquema v4 con ALTER TABLE (0442b14, 5c743bb).

PROMPT

> La pantalla de cuenta está vacía: foto con PickVisualMedia guardada en filesDir, edición de nombre y selector de tema sistema/claro/oscuro aplicado desde Application para que no parpadee.

Prompt 7 · Cuenta completa CuentaActivity con avatar, nombre y tema.

PROMPT

> Un compañero clonó el repositorio y le crashea al abrir; en mi equipo corre. Audita dependencias declaradas contra transitivas, compatibilidad de AGP y SDK, y el arranque en frío. No quiero un proyecto que dependa de mi máquina.

Prompt 8 · Compatibilidad real Dependencias explícitas, stack fijado (AGP 8.13.2 / SDK 36) y nueve pruebas (801959b).

PROMPT

> Pásame el checklist de verificación final con los comandos exactos; lo corro yo en Android Studio, no tú: clon limpio, assembleDebug, testDebugUnitTest y lintDebug. Todo tiene que salir en verde desde cero.

Prompt 9 · Verificación fuera del alcance del agente Cuatro comandos desde un clon limpio, todos en verde.

El patrón de los nueve: pedir el algoritmo o la API exacta y exigir el commit o el comando que demuestra el resultado. Un agente sin evidencia exigida optimiza para complacer; con evidencia, optimiza para cumplir.

Uso de la IA en la documentación

Los cuatro documentos versionados del repositorio (vulnerabilities.md, best_practices.md, security_tips.md y security_improvement_program.md), el reporte de vulnerabilidades y el informe técnico se redactaron con asistencia del mismo agente y se contrastaron contra el código: si un párrafo no tenía comando, volcado o captura que lo respaldara, se corregía o se eliminaba. El equipo revisó completo antes de la entrega. Este anexo sigue la misma regla.

Qué delegué y qué no

Se delegó a subagentes	Se resolvió en serie
Módulos de autenticación, gastos, suscripciones y panel	Esquema de base de datos y sus migraciones
Investigación de referencias de UX	Sesión cifrada y política de respaldo
Documentación de módulos	Corrección de vulnerabilidades y verificación final

Qué verifiqué antes de aceptar

- Compilación limpia y reproducible: assembleDebug y assembleRelease con R8.
- Las 9 pruebas automatizadas ejecutadas de nuevo, no reportadas de memoria.
- Prueba manual en el teléfono con el flujo completo.
- También desde un clon limpio, para detectar lo que solo pasaba en mi máquina (y que efectivamente pasó: el clon de un compañero fallaba aunque acá funcionara).